

Northbridge Assurance Review

Assurance report on the Northbridge Ledger Reconciliation & Anomaly Detection Agent

Subject	Northbridge Ledger Agent, commit 9c4127ad65aa5a9e7d362c2d05f69ecfdbf7c5f9 (23 September 2026)
Report date	23 September 2026
Nature	Self-assessment using audit methodology. The reviewer is also the developer of the system. This is not an independent audit and gives no assurance opinion or certification.
Challenge	Testing was challenged by a separate Claude session (model-based). See section 2 and Appendix D.
Data	Synthetic and vendor sandbox data only. No real client data.

How to read this report

Section 1 gives the conclusion and the numbers a decision maker needs. Sections 2 to 7 give scope, method, results, controls, findings and remediation. Appendices give the framework mapping, the control matrix extract, the evidence index and the challenge review. All figures come from a constructed test set designed by the reviewer after reading the rules; they describe how the system behaves on that set and are **not estimates of accuracy on real books**.

1. Executive summary

Conclusion. As at commit 9c4127a, Northbridge should **not be relied on as a control** for month-end reconciliation or anomaly review. It works as a demonstration and as a lead generator for the error types it was built to find, and it is fast and transparent. But it missed a whole error class (duplicate supplier bills), its reconciliation output changes with the order records are loaded, it keeps no record of what it ran, and it has no step where a person accepts or rejects a flag. On the eight criteria set before testing, seven were not met. A finance director could use it to prompt questions; they should not use a clean run as evidence that a ledger is free of duplicates or breaks.

What was reviewed

Northbridge reconciles bank lines against invoices and bills from Xero and QuickBooks and flags seven kinds of anomaly (A1 to A7). It **calls no LLM**: it is deterministic rules and a median/MAD statistical check, with templated variance sentences. The review therefore treated it as a rules-based automated control and marked LLM-specific risks (prompt injection, hallucination, provider privacy) as not applicable.

Key results

Measure	Result	Criterion	Assessment
Recall, duplicates and reconciliation breaks	83.3% (15/18)	>= 95%	Not met
Recall, other rules (VAT, threshold, weekend, outlier)	100% (13/13)	>= 85%	Met on point estimate; interval spans threshold
Precision	56.0% per item (53.7% per flag)	>= 80%	Not met
F1	0.691	>= 0.85	Not met
False positive rate	11.1% (22/199)	<= 10%	Not met (borderline, label-sensitive)
Determinism (same data, any row order)	Differs in 6 of 7 orderings tested	100%	Not met
Audit trail completeness	0% (no run log)	100%	Not met
Human disposition of flags	0% (no such step)	100%	Not met

Top findings

F-01 Duplicate supplier bills are never detected (0 of 3): the duplicate check covers sales invoices only. **F-02** The reconciliation matcher takes the first match it finds, so results depend on record order and a genuine duplicate payment can vanish. **F-03** No run log. **F-04** No human sign-off, owner or intended-use statement. **F-05** The published 7/7 accuracy result is circular, and the public dashboard shows a hard-coded score. Eight further findings (6 Medium, 2 Low) are in section 6.

Remediation

The Northbridge project was **not changed**. Fixes for eight findings (two only partly) were made in a scratch copy and delivered as a patch. On the same frozen dataset, duplicate supplier bills went from 0/3 to 3/3, output became identical across all seven row orderings, and variance sentences naming an opposing driver fell from 17 of 52 to 0 of 59. Two costs are disclosed: one duplicate payment (BT-044) is no longer flagged as such, and the project's published synthetic precision falls from 0.778 to 0.712. The fixes were designed against the same dataset used to retest, so they show the fixes work on those cases, not that real-world accuracy has improved.

What a decision maker should take from this

Use it as a demonstration or an additional analytic. If it is to be used in a close process, first apply the patch, add a disposition step and run log, and test it on data the rules were not written to fit. An external auditor would take no controls reliance on it in its current form (section 7 and *fs_audit_implications.md*).

2. Scope, criteria, approach, independence and limitations

Objective and scope

Assess whether Northbridge is governed, controlled and performs reliably enough to support month-end reconciliation, treating it as an automated control within an IT application. In scope: the Xero and QuickBooks connectors, data loading, reconciliation matcher, anomaly rules A1 to A7, variance explanations, the Streamlit dashboard, oversight, logging, change control, access, secrets and transparency. Out of scope: Sage or other connectors, production or real client data, LLM-specific tests (no LLM exists), penetration testing and Streamlit Cloud platform security.

Reference frameworks

NIST AI RMF 1.0 as a governance lens; ISO/IEC 42001 Annex A, 23894 and 42005 where relevant; PRA SS1/23 for validation and change control; the five UK AI principles; OWASP LLM Top 10 considered and marked not applicable; ISA 315 (Revised 2019), 330, 500 and 265 for financial statement audit implications. Framework sub-references were cited at area level and must be checked against the source documents before reliance. EU AI Act dates from the project plan were not verified and are not relied on.

Criteria (fixed before testing)

Eight criteria were set in the Terms of Reference before any test: recall ($\geq 95\%$ for duplicates and breaks, $\geq 85\%$ for other rules), precision $\geq 80\%$, F1 ≥ 0.85 , false positive rate $\leq 10\%$, determinism 100%, audit trail completeness 100% and human disposition 100%. They are this review's criteria, not an industry standard; in a client engagement they would be agreed with the system owner. Recall is weighted above precision because a missed error usually costs more than a false alarm.

Approach

Planning (terms of reference, system description); risk assessment (28 risks scored for likelihood and impact, mapped to frameworks); control matrix (29 controls, gaps recorded, not fixed before testing); testing (a 230-item synthetic ledger with ground-truth labels frozen by hash before the first run, an evaluation harness run against a read-only copy of the pinned commit, control tests, and a challenge review); findings in Condition, Criteria, Cause, Effect, Recommendation form; remediation demonstrated on a copy and retested.

Independence disclosure

The reviewer developed the system, and the rules were built largely with an AI coding tool. Mitigations: criteria fixed before testing, gaps recorded as findings, hashes recorded before the first run (self-attested), and a challenge review by a separate Claude session given the raw evidence and not the reviewer's reasoning (a model-based challenge).

Outcome of the challenge review

The challenge reviewer reproduced every headline metric exactly and raised 12 challenges (3 High, 8 Medium, 1 Low), **all accepted**. The most important: output depends on database row order (verified, and it withdrew an earlier "determinism met" result); the test set was built inside the rules' detection envelope, so the Terms of Reference wording "not written to fit the rules" was wrong and was amended; several labels (weekend, threshold, outlier) rest on narrative the data cannot show; and some control results were overstated and were reworded. Full disposition: Appendix D.

Limitations

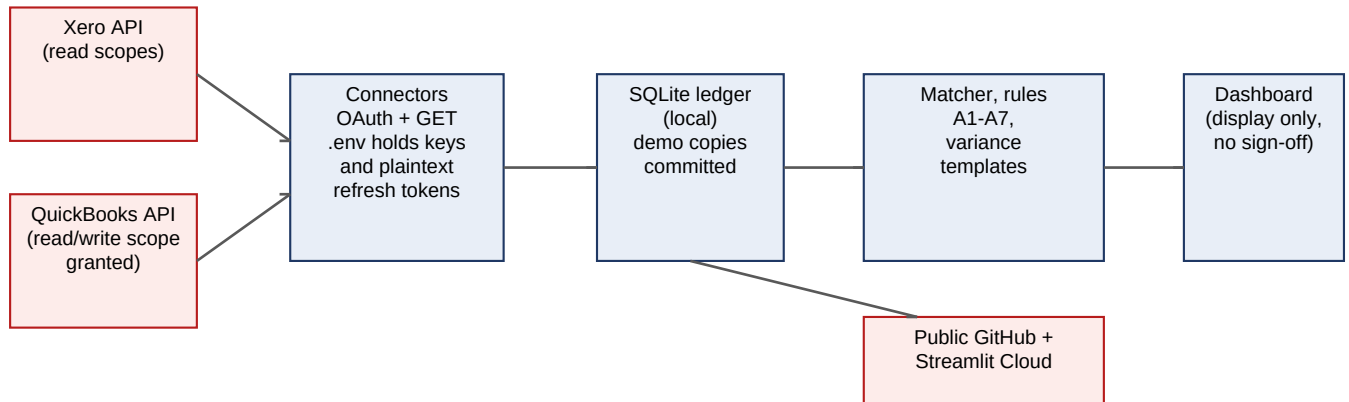
Synthetic and sandbox data only; one reviewer; point-in-time assessment of one commit; 3 to 6 errors per type, so per-type figures carry wide uncertainty; the 22 false positives arise from about six root causes, so simple confidence intervals are too narrow; connector ingestion against live systems, multi-line bills, voided or null data, multi-currency and several rule variations were not tested; the live Xero trial had lapsed, so pagination was not re-tested live; QuickBooks has no answer key, so no accuracy claim is made for it.

3. System overview and regulatory classification

How Northbridge works

Connectors pull ledger data from Xero (read-only scopes) and QuickBooks (a read/write scope is granted, but the code only reads) into a local SQLite database. A matcher pairs each standalone bank line with an invoice or bill by amount, date and contact. Six rule checks and one statistical check then flag anomalies, and a template writes plain-English variance sentences. A Streamlit dashboard displays the results. The public deployment runs on frozen snapshots and makes no live API calls.

Data flow (red = data leaves the developer machine)



No LLM provider receives data. Personal data risk is low today because the data is fictional or vendor sandbox data (the Xero demo uses real brand names as counterparties; the sample of contact names checked was limited).

Regulatory classification

Question	Conclusion
AI system under the EU AI Act?	Probably not in the default configuration (fixed rules and classical statistics). Borderline if the optional IsolationForest path is enabled.
Prohibited practice; Annex III high-risk use; Article 50 transparency	No; not a listed use; not triggered
Risk tier	Outside scope / minimal risk on the current design
Reassess if	an LLM or trained model is added, real client data is used, decisions about individuals are made, or the tool is placed on the EU market

Against the five UK principles: **safety, security and robustness** partly met; **transparency and explainability** partly met (rules are inspectable, but there is no intended-use or limitations statement for users); **fairness** largely not relevant; **accountability and governance** not met (no owner, sign-off or audit trail); **contestability and redress** not met (no way to record that a flag was wrong or trace a result to a version). This is the reviewer's reasoning, not legal advice; legal status must be re-checked before it is cited.

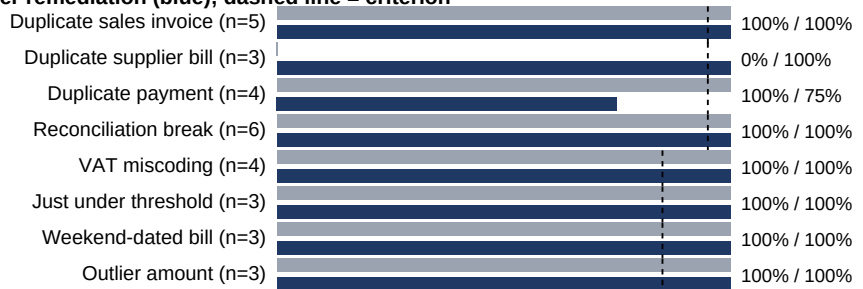
4. Results against criteria

Test set: 230 synthetic items (bills, sales invoices, bank lines) in Northbridge's own schema, with 31 real errors across eight types and 199 clean items, of which 32 are "hard" legitimate items that look like errors (bank charges, weekend suppliers, fixed-price bills, a supplier that became VAT-registered, large one-off purchases). Labels were frozen by hash before the first run. The set is a constructed mix; precision and false positive rates depend on how many hard cases were included (1.2% of standard clean items were flagged, 62.5% of hard ones).

Criterion	Threshold	Result	Assessment
Recall, duplicates and reconciliation breaks	>= 95%	83.3% (15/18)	NOT MET
Recall, other rules (A2, A3, A4, A7)	>= 85%	100% (13/13)	MET on point estimate
Precision (per item, as scored)	>= 80%	56.0% (28/50)	NOT MET
F1	>= 0.85	0.691	NOT MET
False positive rate	<= 10%	11.1% (22/199)	NOT MET (borderline, label-sensitive)
Determinism (identical output on rerun)	100%	Fixed row order: 5/5 identical. Reordered rows: differs in 6 of 7 orderings	NOT MET
Audit trail completeness	100%	0% (no run log exists)	NOT MET
Human disposition of flags	100%	0% (no disposition step)	NOT MET

Item level, any rule: 28 true positives, 3 false negatives, 22 false positives, 177 true negatives. Recall 0.903 (95% interval 0.751 to 0.967), precision 0.560 (0.423 to 0.688), false positive rate 0.111 (0.074 to 0.162). Intervals assume independent items and are too narrow because false positives cluster in about six causes.

Recall by error type: before (grey) and after remediation (blue); dashed line = criterion



Sensitivity to labelling (challenge review)

Precision and false positive rate depend on labelling choices, so they are shown under alternatives. Recall on duplicates and breaks fails only because of the supplier-bill gap, a code limit, not a labelling effect.

Scenario	FP	Precision	F1	FPR	Recall
S0 Base (as frozen)	22	0.56	0.691	0.111	0.903
S1 Weekend and threshold errors relabelled as review indicators (clean)	28	0.44	0.587	0.137	0.88
S2 Drop 6 bank charges	16	0.636	0.747	0.083	0.903
S3 Drop bank charges, legit weekend, fixed-price/boundary bills (15 hard cases)	7	0.8	0.848	0.038	0.903
S4 Drop duplicate supplier bills (A1 scope)	22	0.56	0.718	0.111	1.0

Determinism: five fresh-process runs on one database were identical, but a different row order changed the result in 6 of 7 orderings (one lost a true duplicate payment), so the criterion is not met. **Published results:** the project's 7/7 and 84/84 figures reproduce exactly but use planted anomalies written to fit the rules. Engine speed: about 0.01 s on 230 items.

5. Control assessment summary

The 28 risks were scored before controls: **6 High, 18 Medium, 4 Low** (list in Appendix A). 29 controls were identified from the code and documents: **3 in place, 12 partial, 14 not in place**. Controls that are not in place were recorded as gaps and were not added before testing. Coverage of the 28 risks: 2 covered, 14 partly covered, 11 with a control identified but not in place, 1 with no control identified (R22, vendor and trial changes, accepted as Low). High risks with no working control: R14, R24 (no human disposition step; no run log).

Controls that operated as designed

Xero requests read scopes only and neither connector makes write calls; the local secrets file is git-ignored and was never committed; no credential patterns were found in code files across the full history (a pattern search, not a scanner run); the dashboard's data-quality counts equal an independent recount; every flag carries a reason string; the published accuracy figures reproduce; fixed random seeds work for a given input order.

Controls that failed or are absent (operating result)

ID	Control	In place	Operating result
C03	QuickBooks scope restricted to the minimum (read-only) so the platform enforces read-only	N	Not in place (confirmed)
C05	Refresh tokens stored in a secrets manager or encrypted, not plaintext	N	Not in place (confirmed: plaintext via set_key)
C10	Documented owner, intended use, users of output, known limitations and escalation route	N	Not in place (confirmed)
C13	Completeness and validity check on loaded data (counts reconciled to source, malformed rows rejected or reported)	N	Not in place (confirmed)
C15	Dependencies pinned to exact versions with a lockfile	N	Not in place (confirmed: no pins, no lockfile)
C20	Variance sentences are generated from SQL results by templates, naming the contacts and amounts relied on	Partial	Ineffective in part: figures agree with source (15/15) but 17 of 52 sentences name at least one driver moving against the headline; contacts absent from the later period are never named
C21	Every flag requires a recorded human disposition (accept, reject, reason) before close	N	Not in place (confirmed)
C22	Each flag carries a reason string naming contact, amount and rule, to enable reviewer triage	Partial	Partly effective: reasons present on all 54 flags, but A6 excluded from the contact test; null contact prints 'Bank line for None' (BT-050); correctness of reasons not verified; A4 text asserts a client-specific assumption
C24	Automated regression suite (known errors and clean items) run before each release	N	Not in place (confirmed)
C25	Release tagging and a version stamp on every output	N	Not in place (confirmed: 0 tags)
C26	Run log recording input hash, code version, timestamp, output and user for every run	N	Not in place (confirmed)
C27	README states intended use, known limitations, that the tool is rules-based with no LLM, and its not-for-production status	N	Not in place (confirmed: no such statement in the README)
C28	Dashboard states clearly when a displayed score is a static published figure rather than a computed one	N	Not in place (confirmed)

Full matrix with design tests, planned operating tests, evidence references and results: *03_controls/control_matrix.xlsx*. Controls C12 (pagination against live systems) and C29 (independent challenge) could not be fully tested; see Appendix C.

6. Findings and recommendations

Ratings: **High** can let a material error go undetected or unevidenced, or makes results unreliable; **Medium** weakens reliability, control or transparency and matters beyond a demo; **Low** is minor. Findings describe the system at the pinned commit. Full 5-C write-ups: *05_reporting/findings.md*.

F-01 Duplicate supplier bills are not detected - High	
Condition	0 of 3 duplicated supplier bills flagged; duplicate sales invoices 5 of 5.
Criteria	Recall on duplicates and breaks $\geq 95\%$; result 83.3%.
Cause	Rule A1 selects sales invoices only (rules.py).
Effect	Bills entered twice go unreported; duplicate payables are a principal cash-loss risk.
Recommendation	Run A1 over both sales invoices and supplier bills; add regression cases.
F-02 Reconciliation output depends on record order and mis-attributes recurring payments - High	
Condition	Same data in another row order gave different flags (6 of 7 orderings differ), including loss of a true duplicate payment; two legitimate receipts were attributed to an already-paid invoice of the same amount and flagged as duplicate payments.
Criteria	Identical output for identical data; documents matched correctly.
Cause	Matcher takes the first candidate within tolerance: no ordering, no closest-date preference, no one-to-one allocation (matcher.py).
Effect	Errors can appear or vanish with no change in the ledger. Shown on constructed data; mechanism is in the code.
Recommendation	Deterministic candidate ranking, exclude matched or paid invoices, one-to-one allocation, row-order test.
F-03 No run log or audit trail - High	
Condition	No logging, input hash, code version or timestamp; schema has no audit table.
Criteria	100% of runs traceable to input and code version.
Cause	Not designed in.
Effect	Results cannot be evidenced or re-performed; prerequisite for any reliance is missing.
Recommendation	Append-only run record: input hash, git SHA, dependency versions, timestamp, user, output hash.
F-04 No human disposition of flags; no owner or intended-use statement - High	
Condition	Dashboard displays flags with no accept, reject or reason step; owner and intended use undocumented.
Criteria	100% of flags dispositioned before close; documented accountability.
Cause	Display-only design.
Effect	Oversight cannot be evidenced; no way to record that a flag was wrong or handled.
Recommendation	Disposition record per flag tied to the run log; document owner and intended use.
F-05 Reported accuracy rests on circular validation and a static score - High	
Condition	7/7 and 84/84 reproduce but use anomalies written to fit the rules; public dashboard shows a hard-coded score when the answer key is absent.
Criteria	Accuracy claims evidenced on data not written to fit the rules, with clean items.
Cause	Validation designed to show mechanics; fallback score is a constant.
Effect	Readers may take 7/7 as evidence of general accuracy.
Recommendation	Restate as mechanics tests; label the fallback as static; build an independent test set before any accuracy claim.

Medium and Low findings

ID	Rating	Finding and condition	Recommendation
F-06	Medium	No regression tests, version tags or pinned dependencies. No tests directory, 13 commits, 0 tags, unpinned requirements. Any edit can change detections unnoticed.	Regression suite, tagged releases, pinned dependencies, version in output.

ID	Rating	Finding and condition	Recommendation
F-07	Medium	Variance explanations can point against the headline. 17 of 52 test sentences (35 of 69 on the project's synthetic data) name a driver moving opposite to the headline; contacts that disappeared are never named. Figures agree with source; text is templated, not hallucinated.	Rank drivers in the headline's direction; include disappeared contacts; state share explained.
F-08	Medium	False positives on legitimate items exceed the criterion. 22 of 199 clean items (bank charges 6, fixed-price and boundary bills 5, weekend suppliers 4, VAT registration change 3, large equipment 2, recurring receipts 2). Label-sensitive.	Allow-lists for recurring fixed charges and known weekend suppliers; bank-charge handling; record accepted exceptions.
F-09	Medium	Excess QuickBooks permission; plaintext refresh tokens. Read/write scope granted though code only reads; tokens written in plaintext to a local file.	Read-only scope if offered, else test for no write calls; keychain or secrets manager; rotate tokens.
F-10	Medium	No intended-use or limitations statement for users. The README omits intended use, limits on real books, false negatives and production status, and does not say that no LLM is used.	Describe as rules-based; add intended use and limitations.
F-11	Medium	Data completeness not evidenced. Pagination tested with mocks only; no validation gate; coverage table not reconciled to source.	Reconcile loaded counts and totals to the source system; test ingestion live.
F-12	Low	Hard-coded, unapproved thresholds and message defects. Constants have no rationale or approver; one message reads "Bank line for None".	Documented configuration with approver; fix messages.
F-13	Low	QuickBooks bank purchases all reported as unmatched. 0 of 40 auto-matched; the sandbox has no bills for direct expenses (noise, not a shown matcher failure).	Treat direct expenses as a separate class or state the limitation.

7. Remediation results and financial statement audit implications

Remediation (demonstrated on a copy)

The Northbridge project was not changed. The pinned commit was copied, fixes were applied to the copy and captured in `05_reporting/remediation.patch`, which applies cleanly to a fresh checkout of the pinned commit; its 10 new unit tests pass there. The owner decides whether to apply it. Changes: A1 covers supplier bills; deterministic one-to-one matcher; optional run log (off by default); pinned dependencies, regression tests and a version; variance drivers follow the headline's direction; README rewritten as rules-based with limitations; parameters moved to a config file and messages fixed. Not changed: F-04, F-08, F-09, F-11 and F-13, which need design or process decisions, vendor options or live credentials.

Measure (same frozen dataset and harness)	Before	After	Criterion
Duplicate supplier bills detected	0/3	3/3	
Recall, duplicates and breaks	0.833 (15/18)	0.944 (17/18)	≥ 0.95 , still not met by one item
Precision (per item)	0.560	0.600	≥ 0.80 , not met
F1	0.691	0.741	≥ 0.85 , not met
False positive rate	0.111 (22/199)	0.101 (20/199)	≤ 0.10 , not met (10.05%)
False positives on standard clean items	2/167	0/167	
Identical output across 7 row orderings	No (6 of 7 differ)	Yes (7 of 7)	100%
Variance sentences with an opposing driver	17 of 52	0 of 59	
Published synthetic score	84/84, 24 FP, precision 0.778	84/84, 34 FP, precision 0.712	see below

Costs and limits, stated plainly. (1) The true duplicate payment BT-044 is no longer flagged as a duplicate payment: its bank line now attaches to an unpaid bill of the same supplier and amount, which in this dataset is the deliberately planted duplicate of the paid bill; the tool flags that bill as a duplicate instead. The label was not changed after seeing the result. (2) Ten new supplier-bill duplicate flags on the project's synthetic data count as false positives against its planted list, lowering its published precision. (3) The fixes were designed while looking at this dataset, so the retest shows they work on those cases and does not show accuracy on real books has improved. After remediation two of eight criteria are met (determinism; recall on other rules on point estimate).

Implications for a financial statement audit

Treated as part of an entity's information system (ISA 315), an auditor would take **no controls reliance**:

Layer	Result	Effect
IT general controls (ISA 315)	No run log, no tests, tags or pinning, plaintext tokens and excess scope	Not effective; prevents reliance on automated output
Tool as an automated control (ISA 330)	Duplicates and breaks recall 83.3% vs 95%; output varies with record order	Does not meet the precision needed for payables completeness and accuracy
Human review control	No disposition step, owner or intended use	No management review control to test
Substantive procedures (ISA 330, 500)	Exceptions list is order-dependent and misses supplier duplicates	Auditor re-performs from source data, for example a duplicate analysis over the full payables population

Candidates for written communication of significant deficiencies to those charged with governance (ISA 265), if an entity relied on the tool: F-03 (no audit trail), F-04 (no evidenced review) and F-01 (undetected duplicate payables). Significance depends on the entity and the auditor's judgement. Even with better recall, absent logging and change control would prevent reliance.

Appendix A. Risk register and framework mapping

28 risks, each scored 1 to 5 for likelihood and impact before controls (inherent score = product; High >= 15, Medium 8 to 14, Low < 8). NIST and ISO references are at area level and must be verified against the source texts. Full register with rationale:

02_risk/risk_register.xlsx.

Category	Risks	High	Medium	Low
Accuracy / performance	9	3	4	2
Explainability / transparency	3	0	3	0
Consistency / determinism	1	0	1	0
Data quality	2	0	2	0
Human oversight	2	1	1	0
Security	3	0	3	0
Privacy	1	0	1	0
Change management	2	1	1	0
Third party	2	0	0	2
Monitoring	1	1	0	0
Governance	2	0	2	0
Total	28	6	18	4

High-rated risks

ID	Risk	Score	NIST function / ref	ISO/IEC 42001 area	UK principle
R01	Real errors missed on data unlike the planted patterns (false negatives)	16	Measure / MEASURE 2.3, 2.5	A.6 (life cycle: verification and validation)	Safety, security, robustness
R03	Reported accuracy is overstated because validation was circular (planted anomalies designed to fit the rules)	20	Measure / MEASURE 2.1, 2.3	A.6 (verification and validation)	Appropriate transparency and explainability
R08	Reconciliation attributes bank lines to the wrong document, loses genuine matches or gives different results depending on record order (first match taken, no one-to-one allocation)	16	Measure / MEASURE 2.3	A.6 (verification and validation)	Safety, security, robustness
R14	No human disposition step: flags may be ignored, or actioned with no record	16	Map / MAP 3.5	A.9 (use of AI systems)	Accountability and governance
R20	Rules or thresholds changed without regression testing (no automated tests exist)	16	Manage / MANAGE 4.1	A.6 (life cycle: change)	Accountability and governance
R24	No run log or audit trail (input, code version, timestamp, output) so results cannot be re-performed or evidenced	20	Manage / MANAGE 4.1, MEASURE 2.8	A.6 (records); A.8	Accountability and governance

Risks recorded as not applicable because no LLM is called: prompt injection, hallucinated explanations, provider data handling and retention, silent model changes, model and prompt inventory.

Appendix B. Control matrix extract

Design and operating assessment for a selection of controls. In place: Y = design adequate; Partial = design limited; N = not in place.

ID	Control	In place	Operating result
C01	Xero connector requests only read scopes (granular *.read)	Y	Effective (code and requested scope); portal grant not verified
C02	QuickBooks connector code issues only GET queries and token POSTs	Partial	Operates as described; design limit remains (scope is read/write)
C04	Secrets held in a git-ignored .env; .env.example committed with blanks only	Y	Effective
C06	Repeatable secrets scan before publishing to the public repo	Partial	No matches for credential patterns in code files across all history (regex search; md, csv, db excluded; no scanner run); one-off by reviewer, not repeatable by owner
C11	Data coverage table shows rows loaded per table and data-quality counts (unlinked payments, no-contact lines, voided invoices)	Partial	Operates: dashboard counts equal recount on the same database (arithmetic consistency); not evidence of pull completeness against source totals; no thresholds
C14	Fixed random seeds (IsolationForest random_state=0; synthetic seed 42)	Partial	Fixed seeds work, but output is NOT deterministic across database row order (matcher order dependence, 6 of 7 orderings differ); identical only for a fixed input order
C16	Scoring functions compare detections with an answer key or planted-record list	Partial	Operates (published figures reproduce exactly); low assurance value (circular)
C17	Independent test set not written to fit the rules, with clean items and hard cases, and ground-truth labels	N	Performed by this review: 7 of 8 ToR criteria not met on a constructed mix (see criteria_assessment_full.csv); results are not estimates for real books
C19	Unmatched bank lines are listed for review with contact, date and amount	Partial	Operates: unmatched list equals its own source list (tautological). QuickBooks 0/40 arises from sandbox data with no matching documents; no independent check of match correctness; matcher misattributes recurring receipts and depends on row order
C22	Each flag carries a reason string naming contact, amount and rule, to enable reviewer triage	Partial	Partly effective: reasons present on all 54 flags, but A6 excluded from the contact test; null contact prints 'Bank line for None' (BT-050); correctness of reasons not verified; A4 text asserts a client-specific assumption
C23	Source control with commit history	Partial	Operates: 13 commits, 0 tags, pinned commit reproducible by clone; no review, branch protection or releases

Appendix C. Evidence index

All files are in the review repository. The subject is pinned to commit 9c4127ad65aa5a9e7d362c2d05f69ecfdbf7c5f9. Test dataset and labels were hashed before the first run (self-attested).

Ref	What	Where
E-01	Test dataset and labels frozen (SHA-256 recorded)	04_testing/evidence_log.md; test_dataset/
E-02	Evaluation harness run: metrics, per-type and per-rule results	04_testing/results/
E-03	Determinism (5 fresh processes); withdrawn and corrected in E-06	results/run_metadata.json; results/order_sensitivity.txt
E-04	Control operating tests (scopes, secrets, coverage counts, published-figure reproduction, documentation checks)	results/control_tests_output.txt
E-05	Variance direction check	results/variance_direction_check.txt
E-06	Challenge review outcome and corrections; order sensitivity, sensitivity analysis, full criteria	04_testing/challenge_review.md; challenge_review_raw.md; results/sensitivity.csv; results/criteria_assessment_full.csv
E-07	Remediation demonstrated on a copy; retest	05_reporting/remediation.md, remediation.patch; results_remediated/
-	Terms of reference (with Amendment 1), system description	01_planning/
-	Risk register; regulatory classification	02_risk/
-	Control matrix	03_controls/control_matrix.xlsx
-	Findings; financial statement audit implications	05_reporting/findings.md; fs_audit_implications.md

Not tested: connector ingestion against live systems and pagination (credentials and the Xero trial unavailable); scopes actually granted in the vendor portals; multi-line bills, voided or null data, multi-currency; further rule variations; real-book accuracy.

Appendix D. Challenge review: summary of disposition

ID	Sev	Challenge	Outcome
CH-01	High	Determinism overstated: output depends on row order	Accepted, re-verified; criterion re-rated not met; finding F-02
CH-02	High	Test set built inside the rules' envelope	Accepted; Terms of Reference amended; results reported as a constructed mix
CH-03	High	Weekend, threshold, outlier labels rest on unobservable narrative	Accepted; alternative labelling shown in sensitivity analysis
CH-04	Med	Criterion outcomes flip under relabelling	Accepted; false positive rate reported as borderline
CH-05	Med	Confidence intervals too narrow (clustered false positives)	Accepted; caveat added
CH-06	Med	Only 5 of 8 criteria scored; precision per item not per flag	Accepted; all 8 scored; per-flag 0.537 reported
CH-07 to 09	Med	Control results overstated (C22, C19, C06, C07, C11, C23)	Accepted; wording corrected in the matrix
CH-10	Med	"Likely on real data" is extrapolation	Accepted; reworded as demonstrated on constructed data
CH-11	Med	Coverage not tested (ingestion, multi-line bills, null data)	Accepted as a scope limit
CH-12	Low	Frozen-before-run is self-attested	Accepted; labelled as such